Architettura Tecnica e Sicurezza Informatica nell'Ecosistema PSD2: Protocolli, API e Infrastrutture dei Pagamenti Digitali

L'entrata in vigore della Seconda Direttiva sui Servizi di Pagamento (PSD2) ha segnato una transizione epocale per il sistema finanziario europeo, spostando il baricentro dal controllo centralizzato degli istituti bancari verso un ecosistema aperto e interoperabile basato sul paradigma dell'Open Banking.[1] Sebbene la direttiva sia spesso discussa sotto il profilo giuridico, la sua reale attuazione poggia su un'imponente infrastruttura tecnologica che ha ridefinito i criteri di sicurezza, le modalità di scambio dei dati e l'architettura dei flussi transazionali.[3] Il cuore di questa trasformazione risiede nell'implementazione della Strong Customer Authentication (SCA) e nell'apertura delle Application Programming Interfaces (API) bancarie a terze parti autorizzate, un cambiamento che ha richiesto investimenti tecnologici massicci e l'adozione di standard di sicurezza di grado finanziario.[5] La presente analisi tecnica esamina in dettaglio i pilastri tecnologici della PSD2, esplorando i meccanismi di autenticazione, la sicurezza dei protocolli di autorizzazione e le minacce emergenti in un panorama digitale in continua evoluzione.[4]

La Strong Customer Authentication (SCA) e l'Infrastruttura di Sicurezza

La Strong Customer Authentication (SCA) non rappresenta solo un obbligo normativo, ma è il fondamento tecnico su cui si regge la fiducia degli utenti nel sistema dei pagamenti digitali.[2] Definita dagli Standard Tecnici di Regolamentazione (RTS) dell'Autorità Bancaria Europea (EBA), la SCA impone che ogni accesso ai conti online o inizializzazione di un pagamento elettronico sia validato attraverso almeno due fattori indipendenti tra loro.[10] Questa indipendenza è fondamentale sotto il profilo tecnico: la compromissione di un elemento non deve in alcun modo facilitare la violazione del secondo, garantendo una difesa a più livelli contro gli attacchi informatici.[10]

I Tre Pilastri dell'Autenticazione Multifattore

La logica della SCA si articola su tre categorie di fattori, la cui combinazione tecnica determina il livello di sicurezza della transazione.[2]

Categoria del Fattore	Descrizione Tecnica	Esempi di Implementazione
Conoscenza (Knowledge)	Qualcosa che solo l'utente conosce	Password, PIN, sequenze di sblocco (pattern)

Possesso (Possession)	Qualcosa che solo l'utente possiede	Smartphone, Token hardware, SIM Card, Chiave crittografica
Inerenza (Inherence)	Qualcosa che l'utente è	Impronta digitale, Face ID, riconoscimento vocale, biometria comportamentale

L'implementazione tecnica di questi fattori ha visto una rapida evoluzione. Mentre i fattori di conoscenza come le password sono sempre più vulnerabili ad attacchi di forza bruta o phishing, i fattori di inerenza, supportati dai sensori biometrici degli smartphone moderni, offrono una barriera molto più elevata e una migliore esperienza utente.[1] Il fattore di possesso viene tipicamente verificato attraverso il dispositivo mobile dell'utente, mediante notifiche push firmate digitalmente all'interno di applicazioni bancarie protette, che sostituiscono i vecchi e meno sicuri codici OTP inviati tramite SMS.[9]

Dynamic Linking: Il Requisito dell'Articolo 5 degli RTS

Uno degli aspetti tecnici più complessi e cruciali della PSD2 è il "Dynamic Linking", specificato nell'Articolo 5 degli RTS.[13] Questo requisito impone che, per le transazioni di pagamento remote, il codice di autenticazione generato non sia generico, ma crittograficamente legato all'importo della transazione e al beneficiario.[13] In termini di implementazione, ciò significa che se un utente autorizza un pagamento di 50 euro a un commerciante specifico, il pacchetto di dati firmato digitalmente contiene i metadati della transazione. Qualsiasi tentativo di intercettare il codice e utilizzarlo per un importo diverso o un destinatario differente comporterà l'invalidazione immediata dell'autenticazione.[12]

Il processo tecnico del Dynamic Linking garantisce:

- **Consapevolezza del pagatore:** L'utente deve visualizzare chiaramente importo e beneficiario prima di confermare l'operazione.[12]
- **Integrità della transazione:** La riservatezza e l'autenticità dei dati devono essere mantenute in tutte le fasi del processo.[11]
- **Univocità del codice:** Ogni codice di autenticazione deve avere una durata limitata e poter essere utilizzato una sola volta.[12]

3D Secure 2.0: Il Protocollo Standard dell'Industria

Per rispondere ai requisiti di SCA nel mondo delle carte di credito e debito, il consorzio EMVCo ha sviluppato lo standard 3D Secure 2.0 (3DS 2.0).[16] Rispetto alla versione 1.0, che era caratterizzata da una scarsa compatibilità con i dispositivi mobili e da un'esperienza utente frammentata (i cosiddetti "redirection loop"), il 3DS 2.0 rappresenta un salto di qualità architetturale.[15]

Parametro	3D Secure 1.0	3D Secure 2.0
Integrazione	Browser-based (IFRAME o redirect)	Nativa (SDK per mobile e browser)
Scambio Dati	Circa 15 elementi	Oltre 150 elementi di dati
Autenticazione	Password statica o OTP SMS	Biometria e autenticazione out-of-band
User Experience	Interruzioni frequenti (Friction)	Flussi fluidi (Frictionless)
Analisi del Rischio	Statica e limitata	Dinamica basata su Machine Learning

Il 3DS 2.0 permette alle banche di effettuare una "Risk-Based Authentication" (RBA).[16] Grazie allo scambio di oltre 150 punti dati — inclusi l'ID del dispositivo, la cronologia degli ordini, l'indirizzo IP e le abitudini di navigazione — la banca emittente può determinare con estrema precisione se la transazione è autentica.[15] Se il rischio è valutato come minimo, la transazione può procedere in modalità "frictionless", senza richiedere l'intervento attivo dell'utente, pur rimanendo conforme alla PSD2 grazie alle esenzioni previste per le analisi del rischio transazionale (TRA).[6]

Esenzioni alla SCA: Bilanciare Sicurezza e Usabilità

Gli RTS della PSD2 definiscono una serie di esenzioni tecniche per evitare che l'eccessiva sicurezza comprometta la fluidità dei pagamenti.[23] Queste esenzioni non sono facoltative, ma richiedono che il fornitore di servizi di pagamento (PSP) dimostri di possedere sistemi di monitoraggio delle frodi avanzati.[6]

Le principali esenzioni includono:

- **Pagamenti di basso valore:** Transazioni e-commerce inferiori a 30 euro, fino a un massimo cumulativo

di 100 euro o 5 operazioni consecutive.[24]

- **Contactless al punto vendita:** Pagamenti fino a 50 euro, con limiti cumulativi di 150 euro o 5 operazioni.[24]
- **Beneficiari attendibili (Whitelisting):** L'utente può inserire un esercente in una lista di fiducia presso la propria banca, eliminando la necessità di SCA per gli acquisti futuri.[23]
- **Abbonamenti e pagamenti ricorrenti:** SCA è richiesta solo per la prima transazione di una serie con lo stesso importo e beneficiario.[23]
- **Transazioni a basso rischio (TRA):** Basate sull'analisi in tempo reale dei tassi di frode del PSP.[16]

API e l'Architettura Tecnica dell'Open Banking

L'Open Banking è il pilastro della PSD2 che forza l'interoperabilità tra gli istituti bancari e le aziende Fintech.[1] Tecnicamente, questo si realizza attraverso l'esposizione di Application Programming Interfaces (API) che permettono lo scambio di dati e l'avvio di pagamenti.[3] Le banche, nel ruolo di Account Servicing Payment Service Providers (ASPSP), devono fornire interfacce sicure e documentate affinché le terze parti (TPP) possano operare per conto degli utenti.[1]

Cosa sono le API Bancarie e come funzionano

Un'API bancaria è un insieme di definizioni e protocolli che permette al software di una Fintech di "parlare" con il sistema centrale di una banca in modo standardizzato.[26] La maggior parte delle API Open Banking segue l'architettura REST (Representational State Transfer) e utilizza il formato JSON (JavaScript Object Notation) per lo scambio di dati, garantendo leggerezza e facilità di integrazione.[1]

Il processo di comunicazione tra una TPP e una banca avviene attraverso diversi livelli di sicurezza:

1. **Identificazione tramite certificati eIDAS:** Le TPP devono presentare certificati digitali qualificati (QWAC per l'autenticazione del sito web e QSealC per la firma dei dati) emessi da autorità certificate a livello europeo.[4]
2. **Canale crittografato mTLS:** La connessione tra i server della TPP e quelli della banca è protetta da Mutual Transport Layer Security (mTLS), che garantisce che entrambi gli attori siano autenticati e che i dati non siano intercettabili.[4]
3. **Standard di sicurezza FAPI:** Molte giurisdizioni hanno adottato il profilo Financial-grade API (FAPI), che aggiunge restrizioni crittografiche più severe rispetto all'OAuth 2.0 standard per proteggere contro attacchi di tipo injection e session hijacking.[1]

Protocolli di Autorizzazione: OAuth 2.0 e OpenID Connect

Per gestire il consenso dell'utente senza mai condividere le sue credenziali bancarie (username e password) con la terza parte, la PSD2 utilizza il framework OAuth 2.0.[5] Questo protocollo separa l'autenticazione dell'utente dall'autorizzazione dell'applicazione.[33]

Il flusso tipico di autorizzazione si articola nei seguenti passaggi tecnici:

- **Redirect all'ASPSP:** La TPP reindirizza l'utente alla pagina di login della sua banca.[33]
- **Autenticazione e Consenso:** L'utente esegue il login presso la banca tramite SCA e conferma quali dati vuole condividere (es. saldo, lista movimenti) o quale pagamento vuole autorizzare.[28]
- **Emissione dell'Authorization Code:** La banca restituisce un codice temporaneo alla TPP tramite un URL di callback sicuro.[32]
- **Scambio per l'Access Token:** La TPP scambia l'Authorization Code con un Access Token e un Refresh Token, utilizzando le proprie credenziali client (Client ID e Secret).[32]
- **Accesso ai dati:** La TPP utilizza l'Access Token nelle intestazioni HTTP delle chiamate API successive per recuperare i dati richiesti.[33]

Token	Scopo Tecnico	Durata Tipica
Authorization Code	Codice temporaneo per ottenere i token finali	< 10 minuti [5]
Access Token	Utilizzato per autenticare ogni singola chiamata API	30-60 minuti [34]
Refresh Token	Utilizzato per ottenere un nuovo Access Token senza coinvolgere l'utente	Giorni o Mesi (soggetto a regole SCA ogni 90-180 giorni) [25]

AISP vs PISP: Meccanismi di Accesso ai Dati

Le API si dividono funzionalmente in base al ruolo della TPP, ciascuno con requisiti tecnici e permessi specifici.[6]

I **PISP (Payment Initiation Service Providers)** utilizzano API di "scrittura" per avviare transazioni direttamente dal conto dell'utente.[1] Il flusso PISP è critico poiché richiede il Dynamic Linking: l'API di inizializzazione deve ricevere l'IBAN del beneficiario e l'importo, che verranno poi mostrati all'utente durante la fase di SCA sulla pagina della banca.[11] Una volta completato il flusso, la banca restituisce una conferma dell'avvenuta disposizione, permettendo al PISP di informare l'esercente in tempo reale.[36]

Gli **AISP (Account Information Service Providers)** utilizzano API di "lettura" per aggregare i dati finanziari.[1] Tecnicamente, l'AISP crea una risorsa di "consenso" (Account Access Consent) che specifica quali permessi sono stati concessi, la data di scadenza del consenso e il periodo storico dei dati accessibili (es. ultimi 24 mesi).[26] Un'importante innovazione tecnica dell'AISP è la capacità di aggiornare i dati in background: una volta ottenuto il consenso, l'app può interrogare la banca fino a 4 volte al giorno senza che l'utente debba ripetere la SCA.[28]

Flusso Tecnico di un Pagamento Online: Orchestrazione e Step-by-Step

Un pagamento online in ambito PSD2 non è un'operazione atomica, ma un'orchestrazione complessa di chiamate API e protocolli di sicurezza che coinvolge più domini di fiducia.[2] Analizziamo il percorso tecnico di una transazione e-commerce standard effettuata con carta di credito integrata con 3DS 2.0.

Step 1: Caricamento del Merchant e Tokenizzazione

Quando l'utente inserisce i dati della carta sul sito di un esercente che utilizza un gateway come Stripe o PayPal, i dati sensibili non toccano mai direttamente i server del commerciante.[14] Questo avviene attraverso la **tokenizzazione**: il campo di input della carta è solitamente un elemento protetto (come un iframe o un web component) fornito dal gateway.[8] Il browser invia i dati direttamente al gateway, che restituisce al merchant un "token" univoco. Questo processo riduce drasticamente l'ambito di conformità PCI-DSS dell'esercente e protegge l'utente in caso di data breach del sito e-commerce.[8]

Step 2: Richiesta di Autenticazione (AReq)

Il merchant invia una richiesta di pagamento al proprio acquirer (la banca dell'esercente), che a sua volta contatta il directory server del circuito (Visa o Mastercard).[16] Viene generata una "Authentication Request" (AReq) inviata all'Access Control Server (ACS) della banca emittente.[16] In questa fase, vengono trasmessi i metadati necessari per la Risk-Based Authentication: dati sul browser, impostazioni della lingua, fuso orario, risoluzione dello schermo e dati storici dell'utente.[15]

Step 3: Scelta del Percorso (Frictionless vs Challenge)

L'ACS della banca emittente analizza il rischio della transazione utilizzando motori di intelligenza artificiale.[8]

- **Frictionless Flow:** Se l'analisi del rischio è favorevole, la banca risponde con una "Authentication Response" (ARes) positiva. L'utente non vede alcuna interruzione e viene reindirizzato direttamente alla pagina di conferma dell'ordine.[15]
- **Challenge Flow:** Se il rischio è elevato o la normativa lo impone, la banca risponde richiedendo una verifica aggiuntiva.[16] Il browser dell'utente apre una finestra di dialogo protetta dalla banca emittente.

Step 4: Esecuzione della SCA e Dynamic Linking

In un moderno scenario mobile-first, l'utente riceve una notifica push sul proprio smartphone.[10] Aprendo l'app bancaria, l'utente autentica la propria identità tramite inerenza (impronta digitale o Face ID).[10] Tecnicamente, il dispositivo mobile firma digitalmente una sfida (challenge) crittografica inviata dalla banca, incorporando l'importo e il nome del merchant per soddisfare il requisito del Dynamic Linking.[13]

Step 5: Autorizzazione Finale e Clearing

Una volta validata l'autenticazione, la banca emittente invia un messaggio di successo attraverso il circuito al gateway dell'esercente.[16] Solo a questo punto avviene l'autorizzazione finanziaria vera e propria: la banca blocca l'importo sul conto dell'utente.[16] L'intero processo, sebbene coinvolga decine di server in tutto il

mondo, si conclude tipicamente in meno di 5 secondi.[16]

Innovazioni Tecnologiche: Embedded Finance e Pagamenti Istantanei

La PSD2 ha agito come catalizzatore per nuovi modelli di business che vanno oltre il semplice home banking, portando alla nascita dell'Embedded Finance.[7] Questo termine indica l'integrazione nativa di servizi finanziari all'interno di applicazioni non finanziarie, trasformando ogni software in una potenziale piattaforma bancaria.[42]

Embedded Finance: Meccanismi e Casi d'Uso

L'Embedded Finance è resa possibile dalla modularità delle API PSD2, che permettono di "spacchettare" i servizi bancari tradizionali in componenti atomici pronti per essere integrati.[7]

Modello	Descrizione Tecnica	Esempio Pratico
Embedded Payments	Pagamenti invisibili gestiti in background tramite token e API PISP	Uber: il pagamento avviene automaticamente al termine della corsa [42]
Embedded Lending	Credito concesso istantaneamente al punto vendita (BNPL) tramite analisi Open Banking	Klarna o Shopify Capital: finanziamenti basati sui flussi di cassa in tempo reale [43]
Banking-as-a-Service	Infrastruttura bancaria completa offerta tramite API a brand non bancari	Apple Card: esperienza Apple su infrastruttura bancaria Goldman Sachs [43]
Embedded Insurance	Assicurazione venduta come addon digitale durante un processo di acquisto	Amazon Pay che offre estensioni di garanzia con un clic [43]

Dal punto di vista tecnico, l'Embedded Finance si basa pesantemente sull'uso di SDK (Software Development Kits) che i fornitori di Banking-as-a-Service (BaaS) mettono a disposizione degli sviluppatori.[43] Questi kit gestiscono internamente la complessità della conformità PSD2, della crittografia e della gestione delle sessioni, permettendo all'azienda ospite di concentrarsi sull'esperienza utente.[42]

Pagamenti Istantanei e Architettura Real-Time

Parallelamente alla PSD2, l'area SEPA ha visto l'implementazione del protocollo SCT Inst (SEPA Instant Credit Transfer), che permette il trasferimento di fondi in meno di 10 secondi, 24 ore su 24, 365 giorni l'anno.[38] L'unione di API PISP e pagamenti istantanei crea una minaccia tecnologica diretta ai circuiti di carte tradizionali: un commerciante può ricevere il denaro sul proprio conto quasi istantaneamente, riducendo le commissioni di transazione e il rischio di chargeback, poiché i bonifici istantanei sono definitivi e non stornabili.[2]

Sicurezza Informatica e Anti-Fraud Monitoring

L'apertura dei sistemi bancari attraverso le API ha aumentato la superficie di attacco, richiedendo alle istituzioni finanziarie di adottare strategie di sicurezza "zero-trust".[3] La sicurezza informatica nella PSD2 non è più una questione di perimetri fisici, ma di protezione dei dati in transito e verifica continua dell'identità.[4]

Tecniche di Monitoraggio Avanzate e Machine Learning

La PSD2 impone ai PSP di implementare meccanismi di monitoraggio delle transazioni per individuare tentativi di frode legati alla compromissione delle credenziali.[6] Questo viene realizzato tecnicamente attraverso motori di analisi che operano in tempo reale, spesso basati su modelli di Machine Learning che apprendono continuamente dai nuovi pattern di attacco.[6]

Questi sistemi analizzano diverse dimensioni:

- **Dati comportamentali:** Come l'utente muove il mouse, la velocità di digitazione, e le modalità di interazione con l'app.[6]
- **Fingerprinting del dispositivo:** Analisi di hardware, sistema operativo, versioni dei plugin e configurazioni di rete per rilevare emulatori o dispositivi associati a frodi note.[6]
- **Geolocalizzazione e IP Intelligence:** Confronto tra la posizione dichiarata della transazione e la posizione reale del dispositivo, rilevando l'uso di VPN sospette o proxy anonimi.[6]
- **Analisi della velocità (Velocity Checks):** Monitoraggio della frequenza delle transazioni o dei tentativi di login per bloccare attacchi automatizzati di tipo "credential stuffing".[6]

Crittografia e Tokenizzazione nel Post-PSD2

La crittografia rimane il baluardo fondamentale. Oltre al TLS per i dati in movimento, la PSD2 incoraggia l'uso della crittografia "at-rest" per i dati memorizzati e la pseudonimizzazione dei dati condivisi con le TPP per rispettare il GDPR.[6] La tokenizzazione, originariamente concepita per i numeri di carta (PAN), si sta estendendo ad altri identificatori finanziari, rendendo i dati scambiati tra API privi di valore intrinseco se intercettati da un attaccante.[8]

Cybercrime e Rischi Tecnologici: L'Evoluzione delle Minacce

Con l'irrobustimento delle difese tecniche, i criminali informatici hanno spostato il loro obiettivo verso l'anello più debole della catena: l'utente umano e l'infrastruttura di comunicazione di base.[9] La PSD2 ha reso i "furti di password" meno efficaci, portando alla nascita di attacchi molto più sofisticati che mirano a bypassare direttamente la SCA.[49]

Phishing 2.0 e Proxy-based Attacks (AitM)

Il phishing si è evoluto in quello che gli esperti definiscono "Phishing 2.0" o attacchi Adversary-in-the-Middle (AitM).[52] Invece di creare un sito falso che copia l'estetica della banca, gli attaccanti utilizzano strumenti come EvilProxy o Starkiller per creare un proxy trasparente tra l'utente e la vera banca.[52]

Il meccanismo tecnico è il seguente:

1. **Lure:** La vittima clicca su un link che sembra portare al sito della banca.[53]
2. **Proxying:** Il server dell'attaccante inoltra la richiesta al vero sito della banca e mostra la risposta alla vittima.[52]
3. **Intercettazione SCA:** Quando l'utente inserisce le credenziali e il codice OTP (ricevuto tramite SMS o app), l'attaccante li intercetta e li usa in tempo reale sul sito legittimo.[52]
4. **Session Hijacking:** L'obiettivo finale non è solo la password, ma il "session token" o il cookie di sessione.[52] Una volta ottenuto il token di sessione già autenticato tramite SCA, l'attaccante può operare sul conto senza dover ripetere l'autenticazione per un certo periodo.[52]

SIM Swap: La Compromissione del Canale SMS

Il SIM Swapping è un attacco che sfrutta le debolezze nei processi di verifica dei gestori di telefonia mobile.[48] Poiché molti sistemi SCA utilizzano ancora l'SMS come secondo fattore (possessione), rubare il numero di telefono equivale a rubare l'identità digitale dell'utente.[9]

Il processo non è puramente tecnico, ma si basa sull'ingegneria sociale:

- **Raccolta Dati:** L'attaccante ottiene dati personali della vittima (nome, codice fiscale, data di nascita) tramite phishing o data breach precedenti.[48]
- **Impersonificazione:** L'attaccante contatta il provider telefonico fingendosi la vittima e dichiarando di aver smarrito la SIM, chiedendo la portabilità su una nuova scheda in suo possesso.[48]
- **Acquisizione del numero:** Una volta attivata la nuova SIM, la vittima perde il segnale e l'attaccante inizia a ricevere tutti gli SMS di autenticazione e i link di reset delle password.[17]
- **Svuotamento dei conti:** Con il controllo dell'SMS, l'attaccante può autorizzare bonifici istantanei prima che la vittima si renda conto del disservizio telefonico.[9]

Social Engineering e Furto di Identità Digitale

L'ingegneria sociale rimane la minaccia più pervasiva. Attacchi di "vishing" (phishing vocale) utilizzano l'intelligenza artificiale per clonare la voce di funzionari bancari o dirigenti aziendali (Deepfakes), inducendo dipendenti o clienti a autorizzare transazioni fraudolente.[9] In molti casi, l'utente viene convinto a validare una notifica push sulla propria app bancaria, credendo di "annullare" una frode immaginaria, mentre in realtà sta confermando un pagamento reale avviato dall'attaccante.[9]

Tipologia di Attacco	Meccanismo Principale	Obiettivo Tecnico
Phishing AitM	Reverse Proxy in tempo reale	Furto di Session Cookies e Tokens [52]
SIM Swap	Ingegneria sociale su telco	Intercettazione SMS-OTP [49]
Credential Stuffing	Automazione con liste di	Accesso ad account con

	password rubate	password riutilizzate [6]
Deepfake Vishing	Clonazione vocale tramite AI	Autorizzazione manuale forzata tramite SCA [50]

Implementazione in Italia: Il Ruolo di CBI Globe e dei Provider Nazionali

In Italia, l'adeguamento tecnologico alla PSD2 ha visto la nascita di infrastrutture collaborative per supportare le banche, specialmente quelle di dimensioni minori, nella gestione delle API e della sicurezza.[56]

CBI Globe: Il Gateway Italiano per l'Open Banking

CBI Globe è la piattaforma di RegTech sviluppata da CBI S.c.p.a. (consortium di banche italiane) che funge da gateway centralizzato per oltre l'80% dell'industria finanziaria nazionale.[56] Tecnicamente, CBI Globe standardizza le API di centinaia di banche diverse, fornendo alle TPP un unico punto di accesso per raggiungere la quasi totalità dei conti correnti italiani.[30]

I vantaggi architetturali di CBI Globe includono:

- **Standardizzazione dei flussi SCA:** Gestione uniforme dei diversi metodi di autenticazione (redirect, decoupled, embedded) adottati dalle varie banche.[30]
- **Gestione centralizzata dei certificati eIDAS:** Verifica in tempo reale della validità dei certificati delle TPP che tentano l'accesso alle API.[30]
- **Monitoraggio delle minacce:** Un livello aggiuntivo di rilevamento delle frodi che analizza le chiamate API a livello aggregato per identificare attacchi su larga scala.[30]

SPID e CIE: L'Integrazione con l'Identità Digitale Nazionale

Sebbene la PSD2 non obblighi all'uso di identità digitali governative, in Italia lo SPID (Sistema Pubblico di Identità Digitale) e la CIE (Carta d'Identità Elettronica) sono stati discussi come potenziali fattori di autenticazione forte.[59] La CIE 3.0, grazie al chip NFC e ai suoi 3 livelli di sicurezza, risponde perfettamente ai requisiti di "possesso" e "conoscenza" (PIN), offrendo una base tecnologica sovrana per l'accesso ai servizi finanziari e la firma di transazioni digitali in conformità con il regolamento eIDAS.[59]

Conclusioni: L'Anello Debole e la Strategia Futura (PSD3)

L'analisi tecnica della PSD2 rivela un sistema dove la complessità tecnologica ha raggiunto livelli senza precedenti per proteggere il consumatore.[1] Tuttavia, emerge una verità fondamentale: mentre i protocolli crittografici come mTLS e FAPI sono pressoché inviolabili con le tecnologie attuali, la sicurezza complessiva decade a causa delle vulnerabilità umane e delle debolezze nei canali di comunicazione legacy come l'SMS.[17]

Le lezioni apprese dall'implementazione tecnica della PSD2 stanno già guidando lo sviluppo della PSD3 e del Payment Services Regulation (PSR).[2] La direzione futura prevede:

1. **Abbandono degli SMS:** Spostamento definitivo verso autenticatori hardware o app-based resistenti al phishing.[17]
2. **Miglioramento delle API:** Eliminazione degli ostacoli tecnici (frizioni) che ancora oggi limitano l'adozione dell'Open Banking da parte degli utenti finali.[7]
3. **Collaborazione sui Dati delle Frodi:** Obbligo per i PSP di condividere tra loro informazioni tecniche sulle frodi rilevate per creare una difesa collettiva più efficace.[6]
4. **Verifica del Beneficiario:** Implementazione di sistemi di "Confirmation of Payee" per garantire che l'IBAN inserito corrisponda effettivamente al nome del destinatario, prevenendo truffe basate sull'inganno visivo.[57]

In conclusione, la PSD2 ha trasformato la banca da una fortezza chiusa a un nodo di rete aperto. La sfida tecnologica dei prossimi anni non sarà solo crittografare i dati, ma rendere i flussi finanziari intelligenti, trasparenti e, soprattutto, resistenti alle manipolazioni di un crimine informatico sempre più industrializzato.[4]

Sitografia

1. Open Banking Basics | SecureAuth Connect Product Docs https://docs.secureauth.com/iam/open-banking-concepts-and-terms
2. What is PSD2 everything to know for compliance - Adyen https://www.adyen.com/knowledge-hub/psd2
3. Open Banking Regulations & API Security - Wallarm https://hubspot.wallarm.com/hubfs/Open%20Banking%20Regulations%20and%20API%20Security.pdf
4. What Is PSD2, and How Does It Work? - Curity Identity Server https://curity.io/resources/learn/what-is-psd2/
5. Open Banking Security Profile - Developer Zone - Confluence https://openbanking.atlassian.net/wiki/spaces/DZ/pages/83919096/Open+Banking+Security+Profile+-+Implementer+s+Draft+v1.1.2
6. What is PSD2? Here's what businesses need to know - Stripe https://stripe.com/resources/more/what-is-psd2-here-is-what-businesses-need-to-know
7. APIs as Catalysts: A Bank's View on Open and Embedded Finance - CIO TechWorld https://ciotechworld.com/apis-as-catalysts-a-banks-view-on-open-and-embedded-finance/
8. Tokenization in Finance: How AI Enhances Security and Transparency - sifars-wordpress https://www.sifars.com/en/blog/tokenization-in-finance-how-ai-enhances-security-and-transparency/
9. The Evolution of SIM Swapping Fraud: How Fraudsters Bypass Security Layers - Group-IB https://www.group-ib.com/blog/the-evolution-of-sim-swapping-fraud-how-fraudsters-bypass-security-layers/
10. PSD2 SCA Compliance - GPayments https://www.gpayments.com/about/psd2-strong-customer-authentication-3d-secure-2/
11. Information paper Strong Customer Authentication under Payment Services Directive 2 (PSD2) SWIFT launches advanced token technol https://www.swift.com/swift-resource/71316/download?language=en
12. Understanding Dynamic Linking in PSD2 | Twilio https://www.twilio.com/en-us/blog/insights/compliance/dynamic-linking-psd2
13. What is Dynamic Linking in PSD2? - Okay | Frictionless & Secure ... https://okaythis.com/blog/what-is-dynamic-linking
14. What is PSD2? A guide to PSD2 compliance | Stripe https://stripe.com/ae/resources/more/what-is-psd2-here-is-what-businesses-need-to-know
15. 3DS 2.0 - The Complete Guide | Kount https://kount.com/blog/what-is-3d-secure-2
16. 3D Secure Authentication: The Complete Guide - ACI Worldwide https://www.aciworldwide.com/3d-secure-authentication
17. SIM-swap fraud: Scam prevention guide - Specops Software https://specopssoft.com/blog/sim-swap-fraud-prevention-guide-2025/
18. Dynamic Linking with Passkeys: Secure Payment Confirmation (SPC) - Corbado https://www.corbado.com/blog/dynamic-linking-passkeys-spc
19. 2020_5366 Clarification on where the creation of the authentication code with dynamic linking for strong customer authentication (SCA) for electronic remote payment needs to be done | European Banking Authority https://www.eba.europa.eu/single-rule-book-qa/qna/view/publicId/2020_5366
20. Response to consultation on RTS specifying the requirements on strong customer

authentication and common and secure communication under PSD2 https://www.eba.europa.eu/eba-response/98
21. What is 3D Secure? The Evolution from 1.0 to 2.0 - PayPro Global https://payproglobal.com/answers/what-is-3d-secure/
22. Learn what the 3DS 1.0 sunset means for merchants | Blog - Primer https://primer.io/blog/3dsecure-1-sunset
23. SECURITY - Strong Customer Authentication (SCA) - Mastercard https://www.mastercard.com/gateway/payment-solutions/secure-payments/strong-customer-authentication.html
24. PSD2 & Strong Customer Authentication https://docs.thredd.com/psd/Content/PSD2/PSD2_Rules.htm
25. PSD2 Compliance - Q&A - OneSpan https://www.onespan.com/sites/default/files/2019-08/psd2-webinar-qa-with-answers-public-fme-v4_tcm42-56390.pdf
26. How Open Banking APIs Work: Benefits, Security & Best Practices - DECTA https://www.decta.com/company/media/how-open-banking-apis-work-benefits-security-and-best-practices
27. What are open banking APIs? Complete guide to specifications and standards - Tyk.io https://tyk.io/learning-center/open-banking-apis-explained/
28. Open Banking API Development: Key Features & Best Practices - Zymr https://www.zymr.com/blog/open-banking-api-development-a-complete-guide
29. 5 Steps to Implement OAuth 2.0 in Banking APIs - Lucid https://www.lucid.now/blog/implement-oauth-2-0-banking-apis-steps/
30. CBI Globe - Funzionalità attiva - Nexi Group https://www.nexigroup.com/en/business/banks-and-financial-institutions/open-banking/active-functionality/
31. Getting Started - Open Banking API Security Profile https://standards.openbanking.org.uk/security-profiles/get-started-obl-api-security-profile/
32. OAuth 2.0 workflow - IBM https://www.ibm.com/docs/en/tfim/6.2.2.6?topic=overview-oauth-20-workflow
33. OAuth 2.0 Basics - Authlete https://www.authlete.com/developers/tutorial/oauth/
34. An Introduction to OAuth 2 | DigitalOcean https://www.digitalocean.com/community/tutorials/an-introduction-to-oauth-2
35. OAuth 2.x and OpenID Connect sequence diagrams - /dev/posts/ - gabriel.urdhr.fr https://www.gabriel.urdhr.fr/2023/02/06/oauth2-diagrams/
36. Payment Initiation API Specification - Developer Zone - Confluence https://openbanking.atlassian.net/wiki/spaces/DZ/pages/1077805743/Payment+Initiation+API+Specification+-+v3.1.2
37. PSD2 - Frequently Asked Questions - Central Bank of Ireland https://www.centralbank.ie/regulation/psd2-overview/faq
38. Payment Initiation overview | Worldline Financial Services Developer Portal https://financial-services.developer.worldline.com/digital-services/open-banking/payment-initiation-overview
39. PSD2 - Web Commerce Interest Group - W3C https://www.w3.org/Payments/IG/wiki/PSD2
40. Open banking API specifications: simplifying a technical resource ... https://gocardless.com/guides/posts/open-banking-api-specifications/
41. The power of tokenization in payments | NatWest Corporates and ... https://www.natwest.com/corporates/insights/technology/the-power-of-tokenization-in-payments.html
42. The Evolution and Impact of Embedded Finance: A Comprehensive Analysis - InvestSuite

https://www.investsuite.com/insights/blogs/the-evolution-and-impact-of-embedded-finance-a-comprehensive-analysis
43. Open banking vs. embedded finance explained | Stripe https://stripe.com/resources/more/open-banking-vs-embedded-finance-a-guide
44. Embedded finance: Why banks should embrace APIs and blockchain to stay competitive https://www.tsys.com/insights/2025/10/14/embedded-finance-why-banks-should-embrace-apis-and-blockchain-to-stay-competitive
45. 5 Diverse Embedded Finance Examples | by Efi Pylarinou - Medium https://efipm.medium.com/5-diverse-embedded-finance-examples-0b0296897009
46. Open Banking Specifics in Italy | Enable Banking Docs https://enablebanking.com/docs/markets/it
47. The Comprehensive Guide To Payment Initiation Services (PIS) - Brite Payments https://britepayments.com/resources/article/guide-to-payment-initiation-services-pis/
48. A deep dive into the growing threat of SIM swap fraud - Thomson Reuters Institute https://www.thomsonreuters.com/en-us/posts/corporates/sim-swap-fraud/
49. What is SIM Swapping Fraud and How to Prevent It | Trend Micro (US) https://www.trendmicro.com/en_us/what-is/cyber-attack/types-of-cyber-attacks/sim-swapping-scams.html
50. Phishing 2.0: Why Today's Scams Are Harder to Spot Than Ever - XSolutions https://xsolutions.com/phishing-2-0-why-todays-scams-are-harder-to-spot-than-ever/
51. What Is SIM Swapping? Attack, Definition, Prevention | Proofpoint US https://www.proofpoint.com/us/threat-reference/sim-swapping
52. What is Phishing 2.0 and which countermeasures can organisations use against it? https://www.ubisecure.com/security/phishing-2-0/
53. Phishing attacks hijack corporate email threads to deliver login traps - Paubox https://www.paubox.com/blog/phishing-attacks-hijack-corporate-email-threads-to-deliver-login-traps
54. EvilProxy phishing campaign leverages convincing impersonations of enterprise applications - Okta https://www.okta.com/es-es/blog/threat-intelligence/evil-proxy-phishing-campaign/
55. Phishing Kits Target Post-Authentication Weakness in Digital Platforms https://www.efficientlyconnected.com/phishing-kits-target-post-authentication-weakness-in-digital-platforms/
56. CBI Globe https://www.cbi-org.eu/CBI-Globe-en
57. About us - CBI Globe https://www.cbiglobe.com/About-us
58. CBI: Collaborative open finance ecosystems for a market success story 2021-12-13 https://www.fintechfutures.com/partnerships/cbi-collaborative-open-finance-ecosystems-for-a-market-success-story-2021-12-13
59. The Electronic Identity Card (CIE) - Ministero dell'Interno https://www.cartaidentita.interno.gov.it/en/cie/electronic-identity-card/
60. CieID app - The Electronic Identity Card (CIE) - Ministero dell'Interno https://www.cartaidentita.interno.gov.it/en/useful-info-for-citizens/cie-id/